

ARES: A Framework for Measuring Reliability and Failure Modes in Autonomous AI Security Agents

Mohammad Makchudul Alam^{1,2}, Md. Redowan Zaman Anik², Sabrein Serag El Din el Bodour², Moshiiul Islam Mishu³, and Anca Delia Jurcut⁴

¹DNS Research Lab ²BGD e-GOV CIRT, Dhaka, Bangladesh

³EIC Limited, Dhaka, Bangladesh ⁴School of Computer Science, University College Dublin, Ireland

Abstract—Autonomous agents triage alerts in Security Operations Centres, yet their failure conditions are poorly understood. ARES models agent failures as skill–knowledge–capability mismatches. Testing it against 600 live frontier-model executions reveals a calibration gap: agents grow uncertain and abstain under knowledge deficit rather than confidently hallucinate, inverting the assumed reliability risk.

Index Terms—AI agent reliability, cybersecurity, failure taxonomy, hallucination, SOC automation, epistemic gap



1 INTRODUCTION

Security Operations Centres (SOCs) are undergoing a fundamental transformation. Autonomous AI agents (powered by large language models (LLMs) and equipped with tool-use capabilities) now perform threat detection, alert triage, and incident response tasks that were previously the exclusive domain of human analysts [1]. Frameworks such as LangGraph [2] and AutoGen [3] have made it straightforward to deploy multi-step reasoning agents that query SIEM systems, correlate indicators of compromise (IOCs), and recommend containment actions with minimal human oversight. Commercial platforms including CrowdStrike Charlotte AI and SentinelOne Purple AI have begun embedding agent-based automation into production SOC workflows, and the trend is accelerating.

Yet a critical question remains unanswered: *when do these agents fail, and how dangerous are those failures?* The security community has focused heavily on measuring what AI agents can do (detection accuracy, response speed, ATT&CK coverage) while paying far less attention to the conditions under which agents produce incorrect, incomplete, or actively misleading outputs. This gap carries serious operational consequences:

- A **false negative** allows an intrusion to persist undetected for hours or days, expanding the attacker’s foothold while the SOC believes the environment is clean.
- A **hallucinated threat attribution** propagates incorrect IOCs into shared intelligence feeds, poisoning downstream defences across multiple organisations that consume the same threat data.
- A **delayed response**, caused by an agent paralysed by missing tool access or overwhelmed by input complexity, allows an incident to escalate beyond regulatory reporting thresholds.

These are not hypothetical scenarios: they are predictable consequences of deploying agents whose capabilities do not match the demands of their assigned tasks. We call

this the *Skill–Knowledge–Capability (SKC) mismatch* problem: the systematic gap between what a security task requires and what an agent can actually deliver across multiple dimensions including procedural skills, declarative threat knowledge, tool access, reasoning quality, and knowledge currency.

Existing work addresses fragments of this problem in isolation. Classical dependability theory [4] predates LLM agents and has no notion of epistemic uncertainty or knowledge currency. Hallucination research [5] treats reasoning failures as model-internal properties without modelling tool availability, task complexity, or knowledge freshness. Calibration work [6] shows neural networks are miscalibrated but does not connect this to agent reliability. Agent benchmarks [7], [8] measure capability without modelling failure conditions. The closest recent efforts, MAST [9], a domain-agnostic 14-mode failure taxonomy, and AgentDojo [10], an adversarial prompt-injection environment, each cover one slice of the surface. To the best of our knowledge, no existing work provides a unified reliability model, evaluation testbed, and labelled failure dataset for the full non-adversarial failure surface of AI security agents.

This paper presents ARES (Agentic Reliability Evaluation for Security systems), a framework designed to fill this gap. ARES provides:

- 1) A **three-axis failure taxonomy** classifying AI security agent failures by origin (8 classes), manifestation (8 classes), and operational impact (7 classes), grounded in CSIRT practice.
- 2) A **quantitative reliability model** based on SKC mismatch, including an Agent Reliability Score (ARS) with task-class-specific weights and an Epistemic Gap metric that formalises the hallucination precondition.
- 3) **ARES-BENCH**, a fully open-source, Docker-deployable evaluation testbed supporting four agent architectures across five threat scenario classes.
- 4) **SOCAGENTFAILURE-1K**, an analytical corpus of 1,000 agent execution traces under controlled failure conditions,

released under CC BY 4.0.

- 5) A **calibration-gap finding**: testing the model’s central assumption against 600 live frontier-agent executions, we show that real agents grow uncertain and abstain under knowledge deficit rather than confidently hallucinate, inverting the risk the failure model, and much of the literature, assumes.

Together they let SOC architects screen an agent for a given task before it sees production traffic, and, as importantly, tell them which of the model’s assumptions survive contact with real agents.

Parallel 2025–2026 efforts confirm the urgency: hallucination benchmarks [11] treat confident factual errors as a cross-domain failure class, and the OWASP Top 10 for Agentic Applications [12] elevates capability-mismatch and tool-misuse failures to first-class operational risks. None of these efforts connect agent reliability to SOC-specific consequences: a misclassified ransomware beacon or a fabricated CVE attribution. ARES fills that gap.

2 WHY RELIABILITY OF AI AGENTS MATTERS FOR CYBERSECURITY

The reliability of AI agents is not merely an academic concern: it is an operational safety requirement. When an AI agent operates autonomously in a SOC, its outputs directly influence incident response decisions that affect the security posture of entire organisations. Unlike traditional software, where bugs produce deterministic incorrect outputs, LLM-based agents introduce a qualitatively different failure surface: *stochastic, context-dependent, and confidence-inflated errors* that are difficult to detect and dangerous to act upon.

Risks of autonomous AI decisions. A human analyst who encounters an unfamiliar threat pattern will typically escalate or seek additional context. An LLM-based agent, by contrast, may confidently classify a novel threat using superficially similar patterns from its training data, a failure mode known as hallucination. In cybersecurity, hallucination is particularly dangerous because the domain is dense with specific factual claims (CVE identifiers, threat actor names, TTP chains) that are easy to fabricate convincingly but difficult to verify in real time [5]. The consequences of incorrect autonomous decisions are often irreversible: once a compromised host is left un-isolated or a fabricated IOC enters a shared feed, the damage propagates faster than human review can contain it.

Impact on incident response. Consider a three-stage pipeline: triage, enrichment, and remediation. If triage misclassifies a ransomware intrusion as a benign false positive, enrichment never investigates and remediation recommends no action, so the intrusion persists and exfiltration proceeds undetected. If instead triage hallucinates a threat-actor attribution, for example pinning a commodity phishing campaign on an APT group, enrichment may propagate fabricated IOCs to shared STIX/TAXII feeds, corrupting defences across every organisation that consumes them. A third agent lacking EDR containment access (capability mismatch) may identify the threat correctly yet fail to execute isolation, introducing a critical response delay.

Trust and accountability. SOC analysts must trust AI agent outputs enough to act on them, but not so much that

they stop verifying. When agents fail silently, producing plausible but incorrect outputs, they erode this trust calibration over time. Repeated false confidence leads analysts to either over-rely on AI-assisted workflows (automation complacency) or disengage from them entirely (automation aversion), both of which degrade operational effectiveness. The challenge is compounded in organisations subject to regulatory frameworks such as NIS2 or DORA, where accountability for incident response decisions must be traceable regardless of whether a human or an AI agent made the initial assessment.

Why hallucination is uniquely dangerous in SOC environments. Hallucination in security operations is *actionable*. A hallucinated medical diagnosis triggers further tests; a hallucinated legal citation is caught in review; but a hallucinated threat attribution can trigger immediate containment (host isolation, feed updates) with real cost and often no verification checkpoint before execution. High confidence, factual density, and automated downstream actions make SOC hallucination uniquely dangerous among AI application domains.

Why existing assurance approaches fall short. Classical software testing does not catch stochastic, context-dependent agent failures: a test suite that passes at build time says nothing about reliability under a new CVE or novel ransomware variant. SOC peer review is the safety net for sensitive decisions, but autonomous agents are deployed precisely to remove that bottleneck. Adversarial ML benchmarks measure robustness against crafted perturbations rather than against the benign-but-unfamiliar inputs that dominate SOC workload. Hallucination benchmarks [11] count how often models fabricate facts but do not connect fabrication to the downstream security actions that turn a wrong answer into operational harm. These gaps motivate a structured framework for measuring agent reliability *before deployment* and monitoring it *during operation*, which is what ARES provides.

3 FAILURE TAXONOMY FOR AI SECURITY AGENTS

Understanding *how* agents fail is a prerequisite for measuring reliability. We propose a three-axis taxonomy that decomposes each failure event along three orthogonal dimensions: what caused it (*origin*), what it looked like (*manifestation*), and what it cost (*impact*). Unlike prior fault taxonomies developed for conventional software [4], this taxonomy is designed specifically for autonomous AI security agents, where failures are not bugs to be patched but operational risks that affect real-world security outcomes. Table 1 summarises the three axes.

Two distinctions matter for practitioners. First, *Hallucination* (M1) and *Confabulation* (M4) are not synonyms. Hallucination asserts atomic facts that are verifiably false against a closed-world corpus; confabulation produces internally coherent reasoning founded on non-existent premises. Confabulation is more dangerous because it is harder to detect by automated checks and more persuasive to analysts reviewing the agent’s reasoning trace. Second, *Intelligence Pollution* (I5) is qualitatively unlike the other impacts: a single hallucinated IOC pushed to a STIX/TAXII feed propagates

TABLE 1
Three-Axis Failure Taxonomy for AI Security Agents

Code	Class	Description
<i>Axis 1: Origin (root cause)</i>		
O1	Epistemic Deficiency	Lacks required threat knowledge
O2	Skill Boundary	Task requires an unlearned procedure
O3	Capability Deprivation	Required tool or API unavailable
O4	Reasoning Corruption	Inference produces invalid output
O5	Context Overload	Input exceeds processing capacity
O6	Adversarial Perturbation	Malicious content degrades output
O7	Orchestration Failure	Multi-agent coordination breakdown
O8	Temporal Drift	Knowledge has become stale
<i>Axis 2: Manifestation (observable signal)</i>		
M1	Hallucination	Asserts verifiably false facts
M2	Omission	Fails to detect a present threat
M3	Misclassification	Wrong threat family or category
M4	Confabulation	Coherent reasoning from false premises
M5	Paralysis	No output or persistent retry loop
M6	Overclaiming	High confidence on weak evidence
M7	Attribution Error	Wrong threat actor or campaign
M8	Cascade Failure	Error propagates across agents
<i>Axis 3: Impact (operational consequence)</i>		
I1	False Negative	* Threat undetected; attacker persists
I2	False Positive	Benign activity flagged
I3	Delayed Response	Action issued past SLA
I4	Wrong Remediation	* Incorrect containment executed
I5	Intelligence Pollution	* Fabricated IOCs propagate to feeds
I6	Trust Erosion	Analyst confidence reduced
I7	Compliance Violation	Regulatory threshold breached

* Critical impact category.

beyond the originating organisation to the entire information-sharing community.

The power of the three-axis decomposition is its diagnostic composability. A practitioner who observes a cluster of M1 events can trace back to O1 (knowledge deficiency) or O5 (context overload) as the most probable origins, and forward to I1 (false negative) or I5 (intelligence pollution) as the likely consequences. Each origin maps to a distinct operational action: O1 calls for knowledge refresh, O5 for input preprocessing, O3 for tool provisioning.

Worked example: Intelligence Pollution. A pipeline correctly identifies a phishing campaign, but the enrichment stage invents three IOC URLs by extrapolating a domain pattern; a downstream automation pushes them to the shared feed, and within minutes partner SOCs block legitimate subdomains of a real service. The trace decomposes cleanly—origin O1 (missing TTP chain), manifestation M1 (hallucinated facts), impact I5 (blast radius beyond the originating organisation)—and motivates per-IOC confidence gating, confidence-proportional feed propagation, and human review for feed writes, each traceable to a distinct axis.

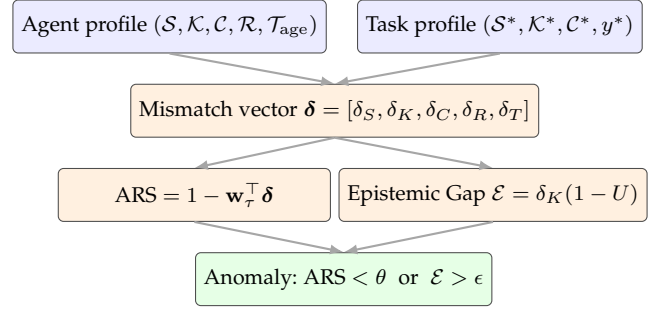


Fig. 1. The ARES reliability pipeline. The agent's declared profile and the task's requirement profile produce a five-dimensional mismatch vector that feeds two parallel indicators: the Agent Reliability Score and the Epistemic Gap. Either crossing its learned threshold flags the execution as anomalous.

4 RELIABILITY MODEL: SKC MISMATCH

The taxonomy tells us *how* agents fail; the reliability model tells us *why* and *how likely*. At its core, ARES measures the gap between what a security task demands and what an agent can deliver across five dimensions. The model extends classical dependability theory [4] by introducing knowledge incompleteness, probabilistic reasoning errors, and capability constraints as first-class failure sources: dimensions that do not exist in traditional deterministic software systems. Figure 1 summarises the end-to-end flow.

4.1 Five Mismatch Dimensions

For each dimension, we compute a normalised mismatch score between 0 (full coverage) and 1 (total mismatch); we summarise each here and specify how it is measured on a real agent in Section 5. Full formal definitions of the agent and task profiles and of each indicator (as set-cardinality ratios over the task's required skills, ATT&CK TTP subgraph, and tool manifest, with an exponential-decay temporal term) are given in the companion technical paper.

- **Skill mismatch** (δ_S): the fraction of required procedural skills the agent lacks. For example, a log-correlation agent assigned binary malware analysis has a high δ_S because the required analytical procedure is outside its repertoire.
- **Knowledge mismatch** (δ_K): the fraction of required threat knowledge missing from the agent's context, measured over the MITRE ATT&CK [13] knowledge graph. An agent unaware of a recently emerged ransomware variant has high δ_K for tasks involving that family.
- **Capability mismatch** (δ_C): the fraction of required tools or APIs the agent cannot access. An agent that recommends host isolation but lacks EDR API access has high δ_C : it knows *what* to do but cannot *do* it.
- **Reasoning mismatch** (δ_R): the divergence between the agent's output and ground truth, capturing inference quality. This dimension is unique in that it can only be measured post-execution.
- **Temporal drift** (δ_T): knowledge staleness modelled as exponential decay, parameterised by the threat domain's volatility. Ransomware intelligence ($\lambda = 0.005 \text{ day}^{-1}$) decays rapidly; APT attribution knowledge ($\lambda = 0.001 \text{ day}^{-1}$) remains stable for longer.

A critical design property: the first three dimensions (δ_S , δ_K , δ_C) and temporal drift (δ_T) can all be computed *before* task execution from the agent’s declared profile and the task’s requirements. In deployment, ARES therefore uses skill, knowledge, capability, and temporal drift for pre-execution screening; reasoning mismatch (δ_R) is used after execution for diagnosis and model improvement.

4.2 Agent Reliability Score

The five mismatch scores are combined into a single **Agent Reliability Score (ARS)**:

$$\text{ARS} = 1 - \mathbf{w}_\tau^\top \boldsymbol{\delta}$$

where $\boldsymbol{\delta} = [\delta_S, \delta_K, \delta_C, \delta_R, \delta_T]$ is the mismatch vector and $\mathbf{w}_\tau$ is a weight vector specific to the threat class τ , learned via ridge regression on labelled training data. An ARS of 1.0 indicates perfect alignment between agent capability and task demand; values below a learned threshold θ^* flag the agent as unreliable for that task.

The weights are learned per threat class because different security tasks stress different dimensions. On the analytical corpus, knowledge coverage ($w_K = 0.35$) dominates for ransomware detection, skill and capability access ($w_S = 0.32$, $w_C = 0.28$) lead for DDoS mitigation, and knowledge with reasoning ($w_K = 0.38$, $w_R = 0.24$) lead for APT investigation; within that model a universal weight vector misestimates reliability by at least 12% on some classes. These values illustrate the model’s structure and must be re-fit on a deployer’s own labelled outcomes.

4.3 Epistemic Gap: The “Confident Ignorance” Problem

The most dangerous agent failures occur not when an agent lacks knowledge, but when it *does not know that it lacks knowledge*, a failure of confidence calibration [6]. We formalise this as the **Epistemic Gap**:

$$\mathcal{E} = \delta_K \times (1 - U)$$

where U is the agent’s expressed uncertainty (complement of its stated confidence). An agent with a large knowledge deficit ($\delta_K \approx 1$) that simultaneously reports high confidence ($U \approx 0$) produces a maximal Epistemic Gap: the precondition for hallucination. Conversely, an agent that correctly identifies its knowledge limits ($U \approx 1$) produces a near-zero Epistemic Gap: it may fail the task but will not fabricate an answer. Whether the dangerous regime actually arises is an empirical question, and one much of the hallucination literature answers by assumption. We test it directly (Empirical Insights) and find that real frontier agents keep U high as δ_K rises, so the maximal-gap precondition is the exception rather than the rule, which makes $\mathcal{E}$ valuable precisely as a detector of that exception.

This concept relates directly to the confidence calibration literature, which has shown that modern neural networks (including LLMs) are systematically overconfident on out-of-distribution inputs [6]. The Epistemic Gap operationalises this finding for the specific case of agentic AI: it measures not just whether the model is miscalibrated in general, but whether that miscalibration occurs precisely where the agent’s knowledge is weakest: the most dangerous combination.

The distinction is critical for SOC operations. An agent that says “I don’t have sufficient context to classify this threat” is safe: it triggers human escalation. An agent that confidently asserts a false threat attribution is dangerous: it triggers automated actions based on fabricated intelligence.

4.4 Cascade Reliability in Multi-Agent Systems

When agents are composed into pipelines, failures propagate through information dependencies. We model this using a directed acyclic graph where each edge represents an inter-agent data flow, and show that cascade reliability is bounded above by the *weakest agent* in the pipeline.

This result has a counterintuitive practical consequence: decomposing a security task into a multi-agent pipeline cannot improve reliability beyond the weakest component agent. It can only reduce it. A triage agent that hallucinates an IOC passes corrupted input downstream, where enrichment inherits and amplifies it and the recommendation agent acts on the compounded error. Our analytical results decompose this effect cleanly. Under a matched-bucket ablation on the analytical corpus (reported in the Empirical Insights section), the reliability loss is attributable almost entirely to pipeline depth rather than to the choice of agent framework, and is roughly three times the size the naive headline gap between single-agent and three-stage pipelines would suggest.

4.5 From Score to Action

Operationally, an ARS assessment runs at task-assignment time and yields three control points. If ARS clears the threshold, the agent runs autonomously. If it falls short, the decomposition itself identifies the cheapest mitigation: a high δ_K calls for a knowledge refresh, a high δ_C for tool provisioning, and a high δ_T for a scheduled retraining cadence. The Epistemic Gap is computed at output time and gates downstream propagation: high- $\mathcal{E}$ outputs go to human review rather than to automated containment or shared threat feeds. Because four of the five dimensions are observable before execution, the screening cost is effectively zero.

5 ARES-BENCH EVALUATION FRAMEWORK

To validate the reliability model empirically, we built ARES-BENCH: an open-source, Docker-deployable testbed for measuring AI security agent reliability under controlled conditions. The design prioritises reproducibility (single-command deployment, all data sources public and versioned), generalisability (multiple agent architectures and threat classes), and controllability (systematic mismatch injection across a structured matrix). The full architecture diagram, data-source manifest, and measurement-pipeline details are maintained in the project artefact repository (see Section 9).

Agents under test. ARES-BENCH evaluates four agent architectures spanning the major paradigms: **AUT-1 (Lang-Graph)** [2], a stateful graph-based ReAct loop; **AUT-2 (AutoGen)** [3], a three-stage multi-agent pipeline (triage $\rightarrow$ enrichment $\rightarrow$ recommendation); **AUT-3 (CrewAI)**, a role-based crew (analyst, enrichment, incident commander); and **AUT-4**, a deterministic Sigma/YARA evaluator with no LLM

component, serving as the $\delta_R = 0$ control. Hallucination is structurally impossible in AUT-4. All LLM-based agents use locally deployed Mistral-7B-Instruct via Ollama.

Controlled mismatch injection. A Mismatch Injector applies controlled degradation across four dimensions ($\delta_S, \delta_K, \delta_C, \delta_R$) at four levels each (0, 0.33, 0.66, 1.0). Mechanisms are deliberately realistic: disabling tool nodes in the agent’s execution graph (δ_S); filtering ATT&CK TTP context from retrieval to retain only a controlled fraction (δ_K); intercepting API calls via a middleware proxy that returns permission-denied errors (δ_C); and inserting misleading content into the system prompt at controlled probability (δ_R). Temporal drift (δ_T) is set parametrically via the agent’s knowledge-age attribute.

Failure measurement. An Anomaly Monitor parses agent output, cross-references claims against ATT&CK and NVD as a closed-world ground truth, and flags any unverifiable claim asserted with confidence > 0.70 as a hallucination candidate. It then computes the five mismatch dimensions, the ARS, and the Epistemic Gap, and assigns taxonomy labels using a rule-based engine validated against human annotations (Cohen’s $\kappa = 0.84$ for origin, $\kappa = 0.91$ for manifestation).

From injection to measurement. Controlled injection is how we *construct* the study, not how the model is instantiated in deployment: each dimension is computed from artefacts a SOC already possesses. *Skill* (δ_S) and *capability* (δ_C) are read from the agent’s registered tool and function manifest, the fraction of the task’s required procedures and APIs it is not wired to invoke. *Knowledge* (δ_K) is measured over context, not weights: the fraction of the task kill-chain’s ATT&CK TTP nodes absent from the agent’s retrieval index or supplied context, exactly computable for a retrieval-augmented agent; a genuinely novel threat matches nothing and drives $\delta_K \rightarrow 1$, precisely the high-risk regime the score should flag. *Temporal drift* (δ_T) uses time since the last knowledge refresh, and expressed uncertainty U is the agent’s stated confidence. Four of the five dimensions are thus prospective, needing no run-time ground truth; only δ_R requires post-hoc comparison. The live-incident harness (Empirical Insights) exercises this path on real CVEs, with no injection.

The SOCAGENTFAILURE-1K corpus (analytical). SOCAGENTFAILURE-1K is a labelled corpus of 1,000 traces stratified across five threat classes (200 each), four agent architectures (250 each), and 16 mismatch conditions. Crucially, its *outcomes*, hallucination, expressed confidence, task success, and the taxonomy labels, are generated from the mismatch inputs by calibrated closed-form models rather than read from live model execution. This makes SOCAGENTFAILURE-1K an analytical instrument: mismatch–failure relationships can be studied under exact ground truth and reproduced deterministically, at the cost of encoding rather than discovering them, which is why this article’s central claim is validated not on SOCAGENTFAILURE-1K but on live agents. The corpus is released under CC BY 4.0 alongside the code.

The live-agent harness. To test the model’s assumptions against reality, ARES-BENCH also drives *real* agents: it applies the same δ_K manipulation to the prompt of a frontier LLM, then measures hallucination against ATT&CK ground truth and records the agent’s own expressed confidence. This is the path behind the calibration-gap result and the live-incident study (Empirical Insights); the harness and its

600-execution output are released with the corpus so the comparison is reproducible. Because frontier models are stochastic and served behind evolving endpoints, re-running the harness reproduces the reported *effects* (rising uncertainty and flat fabrication under increasing δ_K) directionally rather than the exact per-call values; the committed run log is the frozen record behind every number we report.

6 EMPIRICAL INSIGHTS

We first report the result that most changed our own view of the problem, then the analytical findings that motivated the test. The headline is a *calibration gap*: the reliability model, like the broader literature it builds on, assumes that knowledge deficit drives *confident* fabrication, but real frontier agents do the opposite, they express uncertainty and abstain. Practitioners should therefore calibrate their expectations to real model behaviour, not to the failure model.

6.1 The Calibration Gap: Real Agents Abstain Where the Model Predicts Hallucination

Setup. SOCAGENTFAILURE-1K is an *analytical* corpus: its outcomes (hallucination, confidence, task success) are generated from the mismatch inputs by calibrated closed-form models, so that the mismatch–failure relationships can be studied under known ground truth. That construction encodes a specific assumption drawn from the hallucination literature, that an agent’s expressed confidence stays high as its knowledge degrades (“confident ignorance”), producing a steep $\delta_K \rightarrow$ hallucination dose-response. We tested that assumption directly against live agents.

We ran **600 real executions** across five frontier backbones spanning two model families (Claude Haiku 4.5, Sonnet 4.6, and Opus 4.7; GPT-4o-mini and GPT-4o) on ten ATT&CK-grounded SOC scenarios. Knowledge mismatch δ_K was applied as a genuine manipulation, withholding a controlled fraction of the scenario’s ground-truth TTP context from the prompt, and every outcome was *measured* from real output: the agent either named a primary ATT&CK technique (correct, or a fabrication if absent from ground truth) or abstained (“insufficient information”), together with its stated confidence.

Finding. The assumed dose-response does not hold (Table 2). Where the analytical model rises to a 39% fabrication rate at $\delta_K = 1$ with correlation $\rho = 0.92$, real fabrication stays low (0–20%) and only weakly related to δ_K (pooled Pearson $\rho = 0.11$; at most 0.27 for any single model). The mechanism is calibration: real confidence *falls* as knowledge is withheld (Pearson ρ between -0.35 and -0.51 across all five models, both families), inverting the built-in overconfidence the failure model assumes. Because expressed uncertainty rises exactly when knowledge drops, the “confident ignorance” precondition rarely materialises, and confident fabrication, the dangerous quadrant the whole framework targets, occurs in at most 13% of executions. The effect scales with capability: the most capable model, Claude Opus 4.7, fabricated in 0% of 120 executions and instead raised its abstention rate from 10% at $\delta_K = 0$ to 67% at $\delta_K = 1$, while the smallest, GPT-4o-mini, is the least

TABLE 2

Calibration gap: analytical failure model vs. 600 live agent executions across two model families. Fabrication is measured against ATT&CK ground truth; confidence is the agent’s stated value.

Agent	$\rho(\delta_K, \text{fab.})$	fab. at $\delta_K=1$	$\rho(\delta_K, \text{conf.})$	conf. risk
SOCAGENTFAILURE-1K model	+0.92	0.39	≈ 0	high
Haiku 4.5	+0.05	0.13	-0.45	0.09
Sonnet 4.6	+0.27	0.17	-0.35	0.07
Opus 4.7	≈ 0	0.00	-0.40	0.00
GPT-4o-mini	+0.07	0.20	-0.50	0.13
GPT-4o	+0.17	0.07	-0.51	0.03

“conf. risk” = rate of confident fabrication (wrong & conf. ≥ 0.7).

calibrated (13% confident fabrication) yet still far short of the model’s 39%. That the same pattern holds across two independent model families is the point: it is not a quirk of one vendor’s alignment but a general property of current frontier agents.

This corroborates our second real-data probe. On 30 live CISA KEV incidents disclosed after every model’s training cutoff (so $\delta_K \approx 1$ by construction), five frontier LLMs scored identically on surface accuracy (vendor 67%, product 63%, CVE $\leq 3\%$), yet confidence behaviour diverged: the OpenAI models answered almost every record at mean confidence 0.68–0.78, whereas the strongest Claude model abstained on 26 of 30 rather than assert an unsupported attribution.¹ Both studies point the same way: whether an agent hallucinates under knowledge deficit is not a property of the deficit but of the model’s calibration, and modern frontier models are calibrated to abstain.

Comparison to calibration baselines. By the standard metric the agents are well-calibrated: pooled expected calibration error (ECE) [6] is 0.04 (Brier 0.09; $n = 419$ answered runs), well below the levels reported for uncalibrated deep networks. This is exactly why raw confidence alone barely predicts fabrication (AUROC 0.51, chance level): a calibrated agent is confident on both correct answers and the rare miss. The Epistemic Gap—which fires only when high δ_K meets high confidence—separates fabrication better than either single-signal baseline (AUROC 0.68, versus 0.62 for δ_K and 0.51 for confidence), and confidence-ordered selective prediction cuts error from 10% at full coverage to 1% at 25% coverage.

Implication. Do not assume that missing threat knowledge translates into confident fabrication; on well-calibrated agents it translates into *abstention and reduced coverage*. The first-order deployment risk shifts accordingly, from “the agent will confidently invent a threat attribution” to “the agent will decline to act, and a poorly-calibrated agent in the fleet is the exception that still fabricates.” Reliability tooling should therefore watch the confidence signal, not the knowledge gap alone, and treat a low-abstention, high-confidence agent as the anomaly.

1. The specific models evaluated are named above; their exact API version strings and evaluation dates for all runs are recorded in the artefact repository so every result is reproducible.

6.2 Different Mismatches Produce Distinct Failure Signatures

Finding (analytical). Within SOCAGENTFAILURE-1K, each mismatch dimension maps to a diagnostically separable manifestation (chi-square test of independence, $p < 0.001$): capability deprivation (δ_C) predominantly produces *Paralysis* (78%); skill deficit (δ_S) produces silent *Omission* (72%); knowledge gaps (δ_K) produce *Hallucination* (32%) and *Misclassification* (21%); reasoning perturbation (δ_R) produces *Confabulation* (38%) and *Overclaiming* (17%). Because these mappings are part of the model’s construction, we present them as the taxonomy’s *design*, an organising hypothesis about how root causes surface, rather than as an independent empirical discovery; the calibration-gap experiment is what tests such hypotheses against reality.

Implication. The manifestation pattern is a diagnostic fingerprint a SOC can validate on its own telemetry: high paralysis points at tool/API access rather than LLM quality; high confabulation at reasoning corruption or adversarial input rather than knowledge gaps.

6.3 The Epistemic Gap Targets the Residual Risk

Finding. The calibration gap does not make hallucination harmless, it relocates it. Confident fabrication still occurs, just in a minority of executions (0–13% above) concentrated in weaker or mis-prompted agents. This is precisely the case the **Epistemic Gap** $\mathcal{E} = \delta_K \times (1 - U)$ is built to isolate: it is large only when knowledge is low *and* expressed confidence is high. On well-calibrated agents, rising δ_K is met by rising uncertainty, so $\mathcal{E}$ stays small and the gate correctly stays quiet; on the residual confident-ignorance cases, $\mathcal{E}$ spikes. The metric’s value is thus not a headline correlation but a factoring of risk into a “what the agent does not know” term (δ_K) and a “how confidently it acts under that ignorance” term ($1 - U$), of which our data show the *second* to be the operative one.

Implication. Calibration is the actionable lever. Because real agents already hedge under ignorance, the highest-value intervention is to preserve and monitor that hedging, gate high- $\mathcal{E}$ outputs to human review, and flag any agent whose confidence fails to fall as its knowledge does.

6.4 Multi-Agent Composition: an Analytical Bound

Finding (analytical). Within the model, composing agents into a pipeline cannot raise reliability above the weakest stage. A matched-bucket ablation on SOCAGENTFAILURE-1K attributes the AUT-1 vs. AUT-2 gap almost entirely to pipeline depth (17.25%) rather than framework identity (0.13%), and the analytic weakest-link bound holds in 100% of the 250 pipeline records (zero violations). We report this as a property of the cascade model; its real-world magnitude awaits the same kind of live measurement we applied to the calibration question.

Implication. Treat multi-agent decomposition as a reliability cost to be justified, not a default. Prefer validated single-agent designs for critical tasks; if composition is required, add inter-stage verification and confidence-gated propagation so that a low-confidence intermediate output, exactly the calibrated signal above, does not silently seed downstream stages.

7 DEPLOYMENT GUIDANCE FOR SOC TEAMS

ARES translates into concrete guidance for teams deploying autonomous AI agents in security operations, organised around five questions SOC architects face when integrating agentic AI, and closing with a five-step pre-deployment checklist.

When should AI agents be trusted? ARS is proposed as a pre-execution screening signal: an agent scoring below a learned threshold is escalated to a human or reconfigured (add knowledge context, restore tool access). The threshold is deployment-specific and must be fit on the deployer's own labelled outcomes, not transplanted (our analytical corpus is illustrative only). Because four of the five dimensions ($\delta_S, \delta_K, \delta_C, \delta_T$) are computable before execution, screening adds no runtime overhead and slots into SOAR platforms as a pre-condition for autonomous execution [14]. ARS is a screening heuristic, not a validated detector; the calibration signal below is the empirically supported lever.

How can reliability be monitored continuously? The Epistemic Gap enables runtime hallucination risk monitoring: by comparing the agent's stated confidence against its known knowledge coverage, a monitor flags high-risk outputs for human review before they trigger automated actions, valuable for host isolation, threat feed updates, and evidence preservation. Computing $\mathcal{E}$ requires only the agent's confidence and pre-computed δ_K , both already in the execution record.

How should knowledge maintenance be scheduled? The temporal drift model gives the *shape* of a per-domain update schedule: reliability decays with a domain-specific rate λ , so fast-moving domains need more frequent refresh. With illustrative constants ($\lambda = 0.005 \text{ day}^{-1}$ for ransomware, 0.001 for APT attribution) the model implies roughly quarterly versus annual refresh. The constants are not measured here and must be fit on each deployer's own drift data; the contribution is the schedule form, not these particular numbers.

How should multi-agent systems be designed? Cascade analysis shows pipelines amplify rather than mitigate component failures. Prefer single-agent designs for critical tasks, or independently verify per-agent reliability before composition. If multi-agent is required, three mitigations reduce cascade risk: (1) inter-agent verification checkpoints; (2) confidence-gated propagation (low-confidence outputs go to humans, not downstream); (3) redundant agent paths for critical decisions.

How can safer agent systems be built? Our calibration-gap result reorders the usual priorities. (1) *Calibration-first design*, the operative lever: prefer and validate agents whose expressed confidence falls as their knowledge degrades, since it is calibration, not knowledge coverage alone, that determines whether a knowledge gap becomes a confident fabrication. (2) *Knowledge coverage* still matters, but chiefly for *task success*: a well-calibrated but under-informed agent will abstain safely, trading coverage for reliability, so knowledge refresh is a capability investment more than a safety one. (3) *Fail-safe defaults*, preserve and reward the abstention behaviour real agents already exhibit, rather than prompting them to always answer. The one agent configured or

fine-tuned to answer confidently under uncertainty is the dangerous exception, and the one to screen out.

How does this map to regulatory and governance frameworks? The SKC decomposition aligns directly with emerging AI governance standards. The NIST AI Risk Management Framework [14] identifies "valid and reliable," "accountable and transparent," and "safe" as top-tier trustworthiness characteristics: ARES operationalises the first via ARS, the second via the traceable mismatch decomposition, and the third via the Epistemic-Gap escalation gate. The NIST Cybersecurity and AI Profile [15], in preliminary draft, is expected to extend these controls to security-domain deployments, which would make pre-execution reliability gates an auditable practice rather than an internal engineering-hygiene step. At the application layer, the OWASP Top 10 for Agentic Applications [12] catalogues capability over-provisioning, tool misuse, and confident hallucination as distinct risk categories, each of which has a direct analogue in ARES: δ_C over-provisioning, δ_C plus δ_R tool misuse, and the Epistemic Gap for confident hallucination.

A deployment checklist. Distilling the above into a pragmatic checklist for SOC architects yields five steps: (i) estimate pre-execution $\delta_S, \delta_K, \delta_C, \delta_T$ for each intended task class; (ii) apply the task-class-specific weight vector and compare ARS against a threshold fit on local labelled outcomes; (iii) if ARS is below threshold, choose one of three mitigations (knowledge refresh, capability provisioning, or task-scope restriction) and re-score; (iv) instrument the runtime to emit stated confidence alongside each decision and compute $\mathcal{E}$ per record, and prefer agents whose confidence falls under withheld knowledge; (v) schedule knowledge refreshes according to a domain-specific temporal-drift constant fit on local drift data. Each step maps to a concrete engineering artefact (a config change, a telemetry hook, a cron job) so the reliability gate does not stay theoretical.

8 LIMITATIONS AND FUTURE WORK

Analytical corpus. SOCAGENTFAILURE-1K's outcomes are generated from the mismatch inputs by closed-form models, so its dose-response, taxonomy signatures, and cascade bound *encode* the relationships they describe rather than discover them. We treat them as an organising model, and it is exactly this that the calibration-gap experiment tests: the model's central assumption (confident ignorance under knowledge deficit) did not survive contact with real agents. The taxonomy manifestation mapping and the cascade magnitude have not yet been re-measured on live agents and should be read as hypotheses, not validated empirical rates.

Scale and scope of the live study. The calibration-gap result rests on 600 executions across five backbones spanning the Claude and GPT families, ten ATT&CK-grounded scenarios, and a single-technique attribution task, complemented by 30 post-cutoff CISA KEV incidents across five models. This is enough to overturn a universal claim, that frontier agents confidently hallucinate under knowledge deficit as a rule, but not to characterise the full distribution of agent behaviour: fabrication is low (0–20%) and flat in δ_K rather than absent. Broader model coverage (including open-weight and non-frontier agents, where calibration is weaker), more scenarios,

multi-step tool-using agents, and larger real-incident corpora are the natural next steps.

Closed-world hallucination labels. Fabrication is scored against ATT&CK/NVD as ground truth, so a genuinely-related technique absent from a scenario’s curated set can be counted as a fabrication; this makes our real fabrication rates, already low, if anything an over-estimate, which strengthens rather than weakens the calibration-gap conclusion.

Confidence as expressed, not verified. We use the agent’s self-reported confidence. This is the operative signal a monitor would actually read, but eliciting well-calibrated confidence remains an open problem; a poorly-calibrated agent that reports high confidence under ignorance is exactly the residual risk the Epistemic Gap is meant to catch.

Future work re-measures the taxonomy and cascade findings on live agents, extends the calibration study across model families and agent architectures, and connects the confidence signal to runtime gating in a production SOC.

9 CONCLUSION

As AI agents take on greater operational responsibility in defending critical infrastructure, frameworks for understanding their failure behaviour become a prerequisite for responsible deployment. ARES contributes an integrated treatment for the cybersecurity domain: a three-axis failure taxonomy, a skill–knowledge–capability reliability model with an Agent Reliability Score and an Epistemic Gap metric, an open testbed, and an analytical corpus for reproducible study.

Our central result, however, is a corrective one. The reliability model, in common with much of the hallucination literature, assumes that knowledge deficit produces *confident* fabrication. Tested against 600 live frontier-agent executions and a post-cutoff live-CVE study, that assumption inverts: real agents are calibrated, their expressed confidence falls as their knowledge degrades, so they abstain rather than confidently hallucinate, and confident fabrication, the failure the framework is built to catch, occurs in a small minority of cases concentrated in the least-calibrated agents. Knowledge coverage is therefore not the first-order reliability lever the model implies; *calibration* is. The operative deployment questions become: is this agent’s confidence actually tracking its knowledge, and which agent in the fleet is the one that still answers when it should abstain?

The practical guidance follows: monitor the confidence signal, not the knowledge gap alone; gate high-Epistemic-Gap outputs; and treat a low-abstention, high-confidence agent under uncertainty as the anomaly. More broadly, the result is a caution for the field: reliability claims about autonomous agents should be validated on real agents, because the failure modes a plausible model predicts are not always the ones that occur.

ARES, ARES-BENCH, SOCAGENTFAILURE-1K, and the live calibration dataset are publicly released to support reproducible research in AI security agent dependability.²

REFERENCES

- [1] G. Apruzzese, P. Laskov, E. Montes de Oca, W. Mallouli, L. Beira, and A. Chechulin, “The role of machine learning in cybersecurity,” *Digital Threats: Research and Practice*, vol. 4, no. 1, pp. 1–38, 2023.
- [2] LangChain Inc., “LangGraph: Building stateful, multi-actor applications with LLMs,” <https://github.com/langchain-ai/langgraph>, 2024, accessed: March 2025.
- [3] Q. Wu, G. Bansal, J. Zhang, Y. Wu *et al.*, “AutoGen: Enabling next-gen LLM applications via multi-agent conversation,” 2023.
- [4] A. Avizienis, J.-C. Laprie, B. Randell, and C. Landwehr, “Basic concepts and taxonomy of dependable and secure computing,” *IEEE Transactions on Dependable and Secure Computing*, vol. 1, no. 1, pp. 11–33, 2004.
- [5] X. Lin, Y. Ning, J. Zhang, Y. Dong *et al.*, “LLM-based agents suffer from hallucinations: A survey of taxonomy, methods, and directions,” *arXiv preprint arXiv:2509.18970*, 2025.
- [6] C. Guo, G. Pleiss, Y. Sun, and K. Q. Weinberger, “On calibration of modern neural networks,” in *Proceedings of the 34th International Conference on Machine Learning (ICML)*, 2017, pp. 1321–1330.
- [7] X. Liu, H. Yu, H. Zhang, Y. Xu *et al.*, “AgentBench: Evaluating LLMs as agents,” in *Proceedings of the International Conference on Learning Representations (ICLR)*, 2024.
- [8] G. Deng, Y. Liu, Y. Li, K. Wang *et al.*, “PentestGPT: An LLM-empowered automatic penetration testing framework,” in *33rd USENIX Security Symposium*, 2024, pp. 6291–6308.
- [9] M. Cemri, M. Z. Pan, S. Yang, L. A. Agrawal, B. Chopra, R. Tiwari, K. Keutzer, A. Parameswaran, D. Klein, and K. Ramchandran, “Why do multi-agent LLM systems fail?” in *Advances in Neural Information Processing Systems (NeurIPS)*, 2025.
- [10] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, “AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents,” in *Advances in Neural Information Processing Systems (NeurIPS)*, 2024.
- [11] Y. Bang, D. Chen, N. Lee, and P. Fung, “HalluLens: LLM hallucination benchmark,” in *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (ACL)*, 2025.
- [12] OWASP Foundation, “OWASP top 10 for agentic applications (2026),” <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>, 2026, accessed: April 2026.
- [13] B. E. Strom, A. Applebaum, D. P. Miller *et al.*, “MITRE ATT&CK: Design and philosophy,” https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf, 2020.
- [14] National Institute of Standards and Technology, “Artificial intelligence risk management framework (AI RMF 1.0),” National Institute of Standards and Technology, Tech. Rep. AI 100-1, 2023.
- [15] —, “NIST cybersecurity and AI profile (preliminary draft),” National Institute of Standards and Technology, Tech. Rep., 2025, preliminary draft, December 2025.

Mohammad Makchudul Alam is a Researcher with the DNS Research Lab specialising in agentic AI reliability and failure characterisation in autonomous security operations.

Md. Redowan Zaman Anik is an Incident Handler with BGD e-GOV CIRT, focusing on SOC automation and AI-assisted incident response.

Sabreïn Serag El Din el Bodour is a System Analyst with BGD e-GOV CIRT, contributing scenario grounding and failure-trace labelling to ARES.

Moshiul Islam Mishu is a PCI-DSS Auditor and Cybersecurity Professional with EIC Limited, Dhaka, Bangladesh, specialising in PCI-DSS audits, VAPT, SOC, and GRC.

Anca Delia Jurcut is an Assistant Professor at University College Dublin specialising in network security, anomaly detection, and trustworthy AI for cybersecurity.

2. <https://github.com/IntelEyes/ARES-Framework>